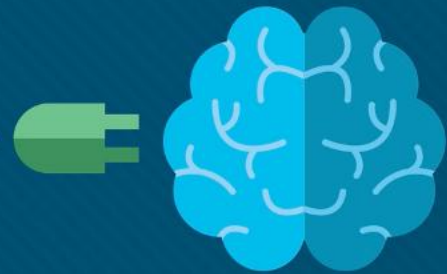




Module 17: Public Key Cryptography

Networking Security v1.0
(NETSEC)



Module Objectives

Module Title: Public Key Cryptography

Module Objective: Explain how a public key infrastructure is used to ensure data confidentiality and provide authentication.

Topic Title	Topic Objective
Public Key Cryptography with Digital Signatures	Explain public key cryptography.
Authorities and the PKI Trust System	Explain how the public key infrastructure functions.
Applications and Impacts of Cryptography	Explain how the use of cryptography affects cybersecurity operations.

17.1 Public Key Cryptography with Digital Signatures

Digital Signature Overview

Digital signatures are a mathematical technique used to provide authenticity, integrity, and nonrepudiation.

The following are characteristics of digital signatures:

- **Authentic** - The signature cannot be forged and provides proof that the signer, and no one else, signed the document.
- **Unalterable** - After a document is signed, it cannot be altered.
- **Not reusable**- The document signature cannot be transferred to another document.
- **Non-repudiated** - The signed document is considered to be the same as a physical document.

Digital Signature Overview (Cont.)

Digital signatures are commonly used in the following two situations: code signing and digital certificates.

There are three Digital Signature Standard (DSS) algorithms that are used for generating and verifying digital signatures:

- **Digital Signature Algorithm (DSA)** - DSA is the original standard for generating public and private key pairs, and for generating and verifying digital signatures.
- **Rivest-Shamir Adelman Algorithm (RSA)** - RSA is an asymmetric algorithm that is commonly used for generating and verifying digital signatures.
- **Elliptic Curve Digital Signature Algorithm (ECDSA)** - ECDSA is a newer variant of DSA and provides digital signature authentication and non-repudiation with the added benefits of computational efficiency, small signature sizes, and minimal bandwidth.

Digital Signatures for Code Signing

Executable files are wrapped in a digitally signed envelope, which allows the end user to verify the signature before installing the software.

Digitally signing code provides several assurances about the code.

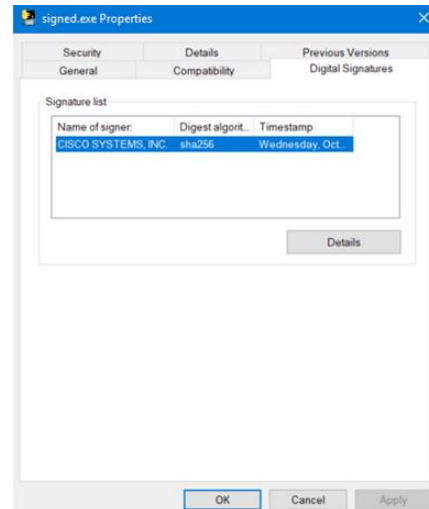
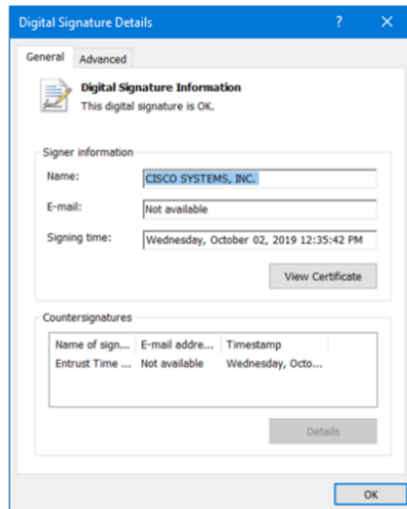
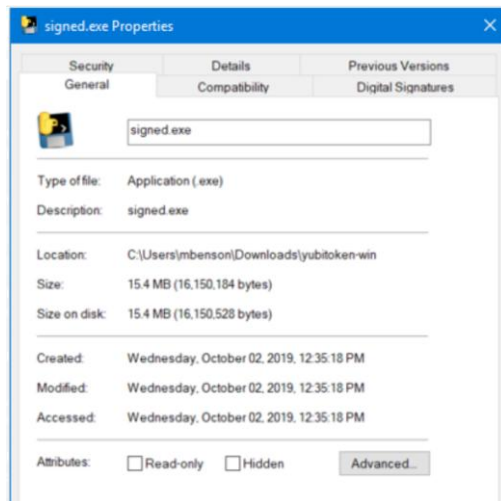
- The code is authentic and is actually sourced by the publisher.
- The code has not been modified since it left the software publisher.
- The publisher undeniably published the code. This provides nonrepudiation of the act of publishing.

Digital Signatures for Code Signing (Cont.)

This executable file was downloaded from the internet. The file contains a software tool from Cisco Systems.

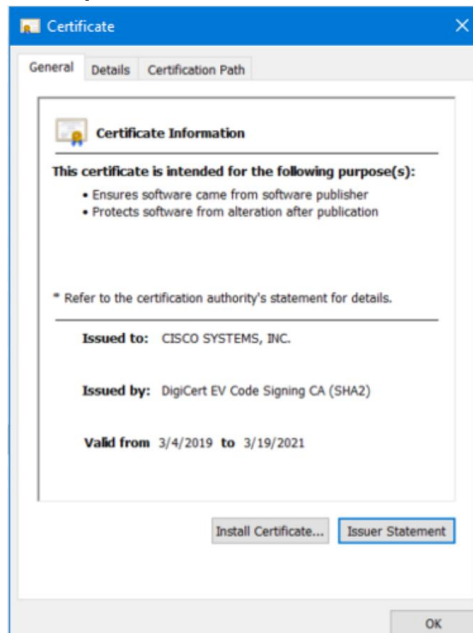
Clicking the **Digital Signatures** tab reveals that the file is from a trusted organization, Cisco Systems Inc.

The Digital Signature Details window reveals that the file was signed by Cisco Systems, Inc in October of 2019.

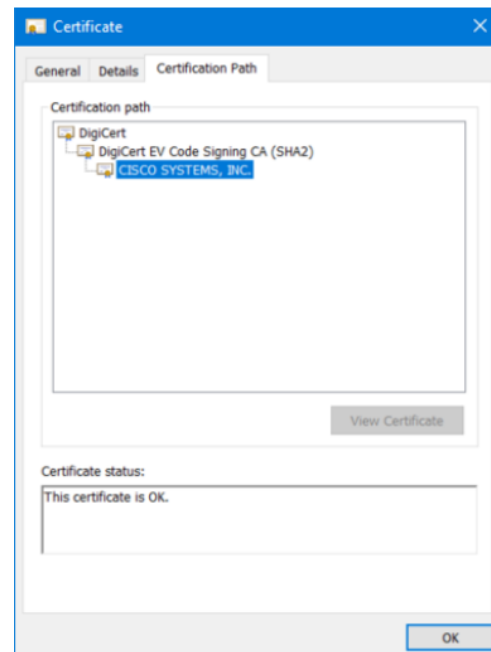


Digital Signatures for Code Signing (Cont.)

The **Certificate Information** tab provides the purposes of the certificate, who the certificate was issued to, and who issued the certificate. It also displays the period for which the certificate is valid.



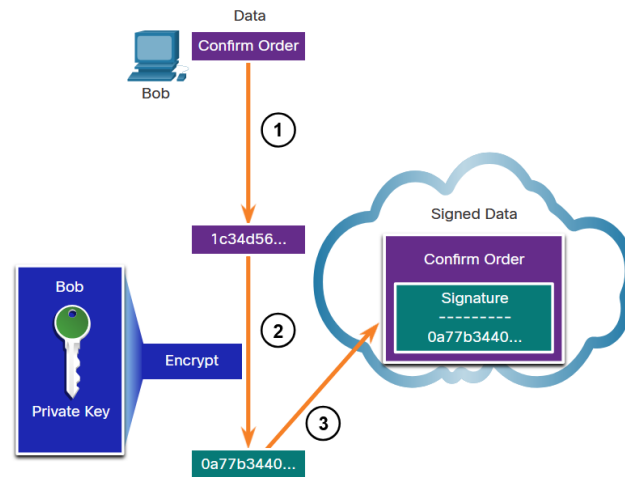
The **Certification Path** tab to see the file was signed by Cisco Systems, as verified to DigiCert.



Digital Signatures for Digital Certificates

A digital certificate is used to authenticate and verify that a user who is sending a message is who they claim to be. Digital certificates can also be used to provide confidentiality for the receiver with the means to encrypt a reply.

This scenario will help you understand how a digital signature is used. Bob is confirming an order with Alice. Alice is ordering from Bob's website. Alice has connected with Bob's website, and after the certificate has been verified, the Bob's certificate is stored on Alice's website. The certificate contains Bob's public key. The public key is used to verify the Bob's digital signature.

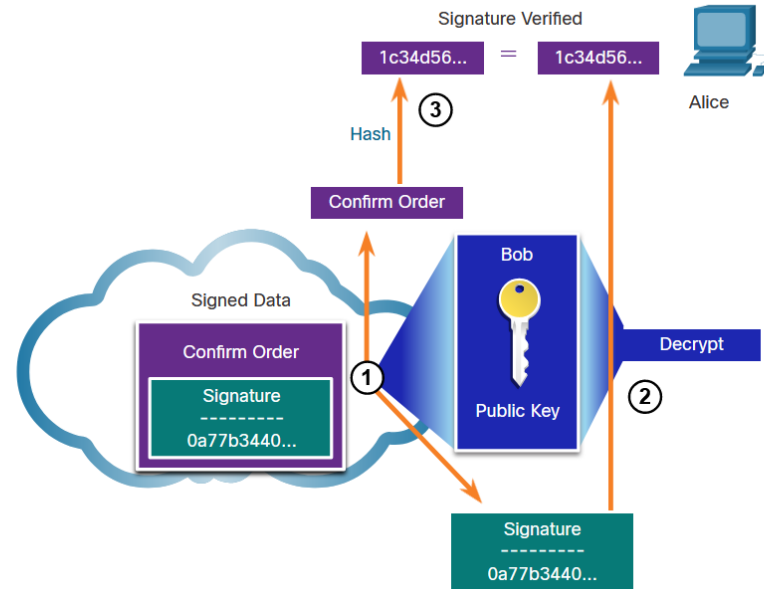


Bob confirms the order and his computer creates a hash of the confirmation. The computer encrypts the hash with Bob's private key. The encrypted hash, which is the digital signature, is appended to the document. The order confirmation is then sent to Alice over the internet.

Digital Signatures for Digital Certificates (Cont.)

When Alice receives the digital signature following process occurs:

1. Alice's receiving device accepts the confirmation with the digital signature and obtains Bob's public key.
2. Alice's computer then decrypts the signature using Bob's public key. This step reveals the assumed hash value of the sending computer.
3. Alice's computer creates a hash of the received document, without its signature, and compares this hash to the decrypted signature hash. If the hashes match, the document is authentic.



17.2 Authorities and the PKI Trust System

Public Key Management

When establishing an asymmetric connection between two hosts, the hosts will exchange their public key information.

An SSL certificate is a digital certificate that confirms the identity of a website domain. To implement SSL on your website, you purchase an SSL certificate for your domain from an SSL Certificate provider.

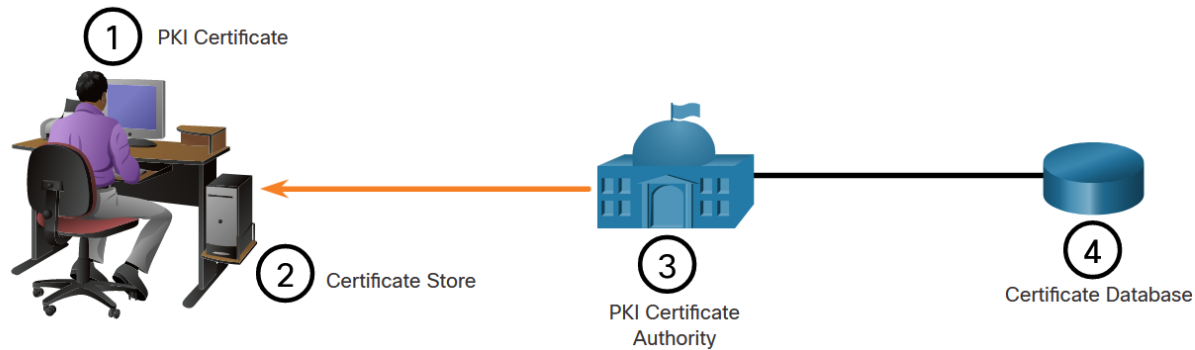
The trusted third party does an in-depth investigation prior to the issuance of credentials. After this in-depth investigation, the third-party issues credentials (i.e., digital certificate) that are difficult to forge. From that point forward, all individuals who trust the third party simply accept the credentials that the third-party issues.

Some examples of Certificate Authorities (CAs) are IdenTrust, DigiCert, Sectigo, GlobalSign, and GoDaddy. These CAs charge for their services. Let's Encrypt is a non-profit CA that offers certificates free of charge.

Public Key Cryptography

Public Key Infrastructure

PKI is needed to support large-scale distribution and identification of public encryption keys. The figure shows the main elements of the PKI.

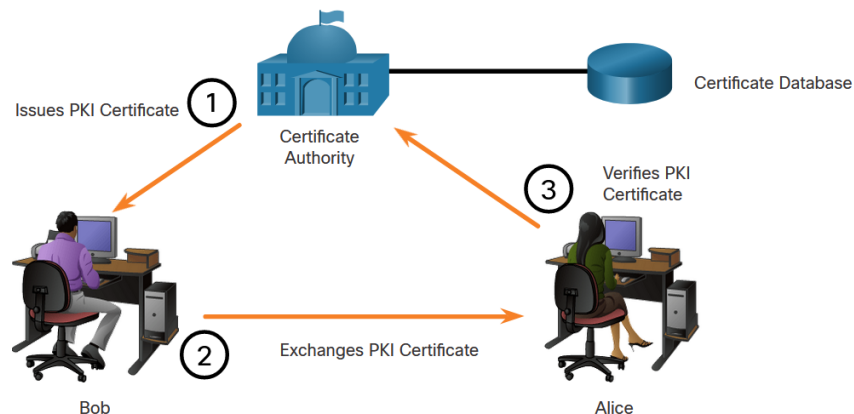


1. PKI certificates contain an entity's or individual's public key, its purpose, the certificate authority (CA) that validated and issued the certificate, the date range during which the certificate is valid, and the algorithm used to create the signature.
2. The certificate store resides on a local computer and stores issued certificates and private keys.
3. The PKI Certificate of Authority (CA) is a trusted third party that issues PKI certificates to entities and individuals after verifying their identity. It signs these certificates using its private key.
4. The certificate database stores all certificates approved by the CA.

Public Key Management (Cont.)

The next figure shows how the elements of the PKI interoperate:

- In this example, Bob has received his digital certificate from the CA. This certificate is used whenever Bob communicates with other parties.
- Bob communicates with Alice.
- When Alice receives Bob's digital certificate, she communicates with the trusted CA to validate Bob's identity.



1. **Issues PKI Certificate.** Bob initially requests a certificate from the CA. The CA authenticates Bob and stores Bob's PKI certificate in the certificate database.
2. **Exchanges PKI Certificate.** Bob communicates with Alice using his PKI certificate.
3. **Verifies PKI Certificate.** Alice communicates with the trusted CA using the CA's public key. The CA refers to the certificate database to validate Bob's PKI certificate.

The PKI Authorities System

CAs, especially those that are outsourced, issue certificates based on classes which determine how trusted a certificate is.

The table provides a description of the classes. The class number is determined by how rigorous the procedure was that verified the identity of the holder when the certificate was issued. The higher the class number, the more trusted the certificate.

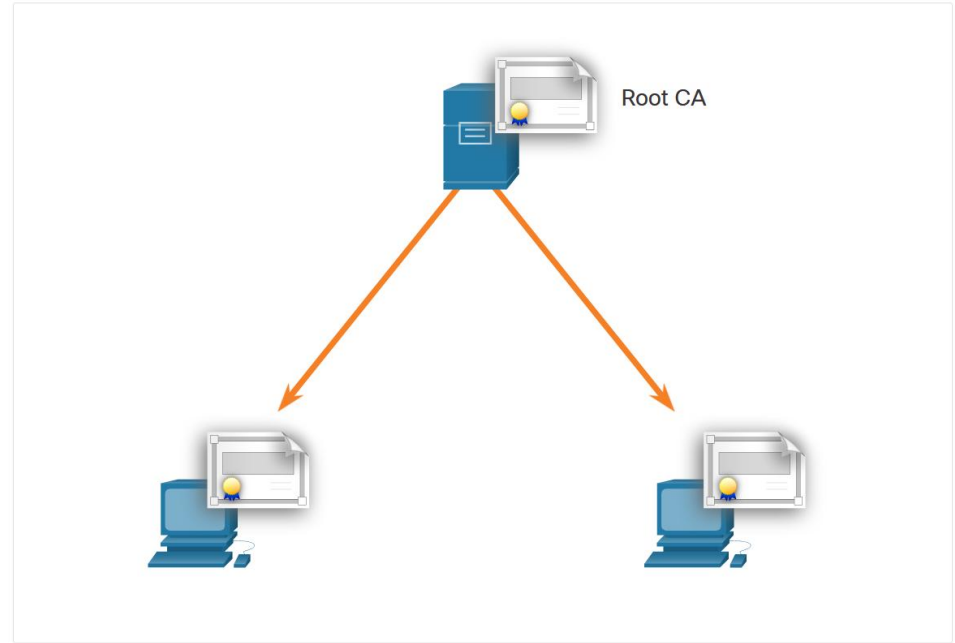
Class	Description
0	Used for testing in situations in which no checks have been performed.
1	Used by individuals who require verification of email.
2	Used by organizations for which proof of identity is required.
3	Used for servers and software signing. Independent verification and checking of identity and authority is done by the certificate authority.
4	Used for online business transactions between companies.
5	Used for private organizations or government security.

Public Key Cryptography

The PKI Trust System

PKIs can form different topologies of trust. The simplest is the single-root PKI topology.

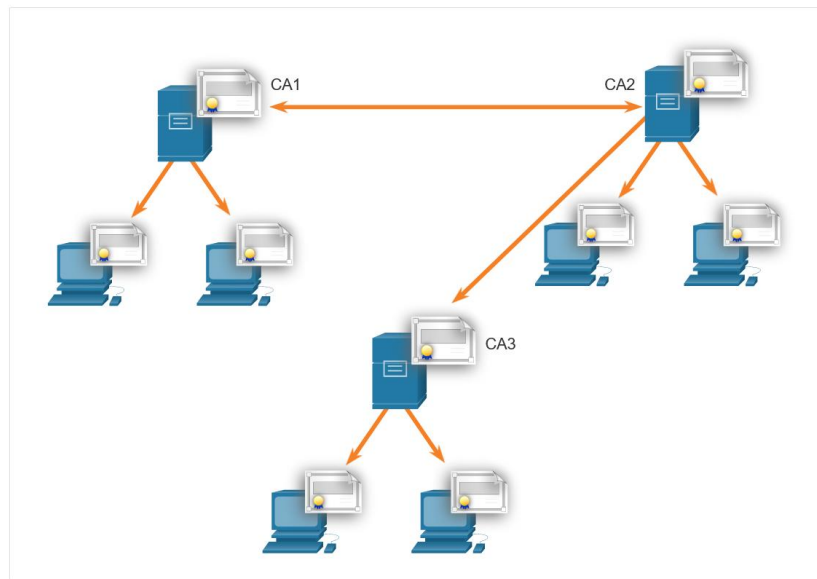
As shown in the figure, a single CA, called the root CA, issues all the certificates to the end users, which are usually within the same organization. The benefit to this approach is its simplicity. However, it is difficult to scale to a large environment because it requires a strictly centralized administration, which creates a single point of failure.



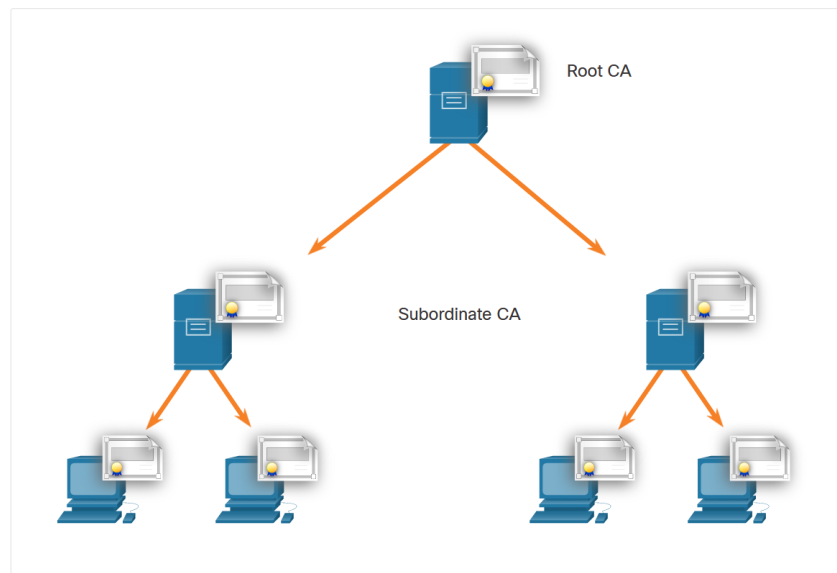
The PKI Trust System (Cont.)

On larger networks, PKI CAs may be linked using two basic architectures:

- Cross-certified CA topologies
- Hierarchical CA topologies



Cross-certified CA

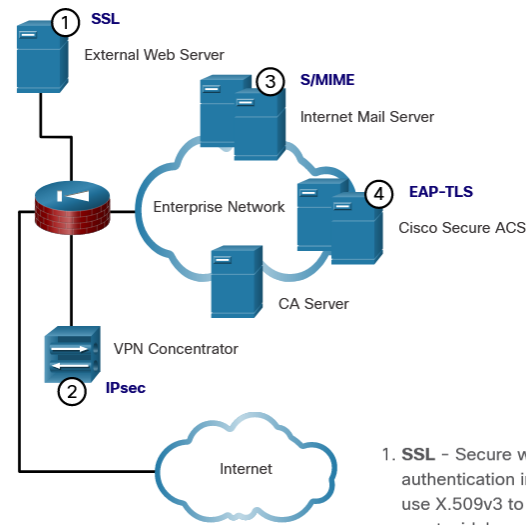


Hierarchical CA

Interoperability of Different PKI Vendors

Interoperability between a PKI and its supporting services, such as Lightweight Directory Access Protocol (LDAP) and X.500 directories, is a concern because many CA vendors have proposed and implemented proprietary solutions instead of waiting for standards to develop.

To address this interoperability concern, the IETF published the Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework (RFC 2527). The X.509 version 3 (X.509 v3) standard defines the format of a digital certificate.



1. **SSL** - Secure web servers use X.509.v3 for website authentication in the SSL and TLS protocols, while web browsers use X.509v3 to implement HTTPS client certificates. SSL is the most widely used certificate-based authentication.
2. **IPsec** - IPsec VPNs use X.509 when certificates can be used as a public key distribution mechanism for internet key exchange (IKE) RSA-based authentication.
3. **S/MIME** - User mail agents that support mail protection with the Secure/Multipurpose Internet Mail Extensions (S/MIME) protocol use X.509 certificates.
4. **EAP-TLS** - Cisco switches can use certificates to authenticate end devices that connect to LAN ports using 802.1.x between the adjacent devices. The authentication can be proxied to a central ACS via the Extensible Authentication Protocol with TLS (EAP-TLS).

Certificate Enrollment, Authentication, and Revocation

- All systems that leverage the PKI must have the CA's public key, which is called the self-signed certificate. The CA public key verifies all the certificates issued by the CA and is vital for the proper operation of the PKI.
- For many systems such as web browsers, the distribution of CA certificates is handled automatically.
- The certificate enrollment process is used by a host system to enroll with a PKI. To do so, CA certificates are retrieved in-band over a network, and the authentication is done out-of-band (OOB) using the telephone.
- Authentication no longer requires the presence of the CA server, and each user exchanges their certificates containing public keys.
- Certificates must sometimes be revoked. The two of the most common methods of revocation are Certificate Revocation List (CRL) and Online Certificate Status Protocol (OCSP).

Lab - Certificate Authority Stores

In this lab, you will complete the following objectives:

- Certificates Trusted by Your Browser
- Checking for Man-In-Middle

17.3 Applications and Impacts of Cryptography

PKI Applications

Where can PKI be used by an enterprise? The following provides a short list of common uses of PKIs:

- SSL/TLS certificate-based peer authentication
- Secure network traffic using IPsec VPNs
- HTTPS Web traffic
- Control access to the network using 802.1x authentication
- Secure email using the S/MIME protocol
- Secure instant messaging
- Approve and authorize applications with Code Signing
- Protect user data with the Encryption File System (EFS)
- Implement two-factor authentication with smart cards
- Securing USB storage devices

Encrypted Network Transactions

Threat actors can use SSL/TLS to introduce regulatory compliance violations, viruses, malware, data loss, and intrusion attempts in a network.

Other SSL/TLS-related issues may be associated with validating the certificate of a web server. When this occurs, web browsers will display a security warning. PKI-related issues that are associated with security warnings include:

- **Validity date range** - The X.509v3 certificates specify “not before” and “not after” dates. If the current date is outside the range, the web browser displays a message. Expired certificates may simply be the result of administrator oversight, but they may also reflect more serious conditions.
- **Signature validation error** - If a browser cannot validate the signature on the certificate, there is no assurance that the public key in the certificate is authentic. Signature validation will fail if the root certificate of the CA hierarchy is not available in the browser’s certificate store.

Applications and Impacts of Cryptography

Encryption and Security Monitoring

Network monitoring becomes more challenging when packets are encrypted.

However, the increased use of HTTPS in the enterprise network introduces new challenges. Because HTTPS introduces end-to-end encrypted HTTP traffic (via TLS/SSL), it is not as easy to peek into user traffic.

Here is a list of some of the things that a security analyst could do:

- Configure rules to distinguish between SSL and non-SSL traffic, HTTPS and non-HTTPS SSL traffic.
- Enhance security through server certificate validation using CRLs and OCSP.
- Implement antimalware protection and URL filtering of HTTPS content.
- Deploy a Cisco SSL Appliance to decrypt SSL traffic and send it to intrusion prevention system (IPS)

17.4 Public Key Cryptography Summary

What Did I Learn in this Module?

- Digital signatures are a mathematical technique used to provide three basic security services: authenticity, integrity, and nonrepudiation.
- Properties of digital signature are that they are authentic, unalterable, not reusable, and non-repudiated. They are commonly used for code signing and digital certificates.
- There are three DSS algorithms that are used for generating and verifying digital signatures: DSA, RSA and ECDSA.
- A digital certificate is used to authenticate and verify that a user who is sending a message is who they claim to be.
- The PKI consists of specifications, systems, and tools that are used to create, manage, distribute, use, store, and revoke digital certificates.
- PKI-related issues that are associated with security warnings include validity date range and signature validation. Some of these issues can be avoided with features of the SSL/TSL protocols.

What Did I Learn in this Module? (Cont.)

- The key components of the cipher suite are the MAC, the encryption algorithm, the key exchange algorithm, and the authentication algorithm.
- Encryption can be used to hide malware command and control traffic between infected hosts and the command and control servers.

New Terms and Commands

- digital signature
- Lightweight Directory Access Protocol (LDAP)
- code signing
- Online Certificate Status Protocol (OCSP)
- Certificate Authority (CA)
- Certificate Revocation List (CRL)
- Elliptic Curve Digital Signature Algorithm (ECDSA)
- Public Key Infrastructure (PKI)
- X.509v3 certificates
- Encryption File System (EFS)
- PKI Trust System

